Static Detection of Access Control Vulnerabilities in Web Applications | USENIX

Back to USENIX

# Static Detection of Access Control Vulnerabilities in Web Applications

Fangqi Sun, Liang Xu, and Zhendong Su, *University of California, Davis*

Access control vulnerabilities, which cause privilege escalations, are among the most dangerous vulnerabilities in web applications. Unfortunately, due to the difficulty in designing and implementing perfect access checks, web applications often fall victim to access control attacks. In contrast to traditional injection flaws, access control vulnerabilities are application-specific, rendering it challenging to obtain precise specifications for static and runtime enforcement. On one hand, writing specifications manually is tedious and time-consuming, which leads to non-existent, incomplete or erroneous specifications. On the other hand, automatic probabilistic-based specification inference is imprecise and computationally expensive in general.

This paper describes the first static analysis that automatically detects access control vulnerabilities in web applications. The core of the analysis is a technique that statically infers and enforces *implicit access control assumptions*. Our insight is that source code implicitly documents intended accesses of each role and any successful *forced browsing* to a privileged page is likely a vulnerability. Based on this observation, our static analysis constructs sitemaps for different roles in a web application, compares per-role sitemaps to find privileged pages, and checks whether forced browsing is successful for each privileged page. We implemented our analysis and evaluated our tool on several real-world web applications. The evaluation results show that our tool is scalable and detects both known and new access control vulnerabilities with few false positives.


## Fangqi Sun, University of California, Davis

## Liang Xu, University of California, Davis

## Zhendong Su, University of California, Davis


## Open Access Media

USENIX is committed to Open Access to the research presented at our events. Papers and proceedings are freely available to everyone once the event begins. Any video, audio, and/or slides that are posted after the event are also free and open to everyone. Support USENIX and our commitment to Open Access.

BibTeX

@inproceedings {266528, author = {Fangqi Sun and Liang Xu and Zhendong Su}, title = {Static Detection of Access Control Vulnerabilities in Web Applications}, booktitle = {20th USENIX Security Symposium (USENIX Security 11)}, year = {2011}, address = {San Francisco, CA}, url = {https://www.usenix.org/conference/usenix-security-11/static-detection-access-control-vulnerabilities-web-applications}, publisher = {USENIX Association}, month = aug }

Download

**Presentation Video**

**Presentation Audio**

MP3 Download OGG Download

Download Audio

### Links

Paper:

http://www.usenix.org/events/sec11/tech/full_papers/Sun.pdf

Slides:

http://www.usenix.org/events/sec11/tech/slides/sun.pdf